

# MVP Dagen

mvpdagen.no



# Takk til våre sponsorer



Se alle våre eventpartnere på skjermen i vandrehallen  
[mvpdagen.no](https://mvpdagen.no)

# Securing your Entra Identities (in 2025)



mvpdagen.no

# Hallo!

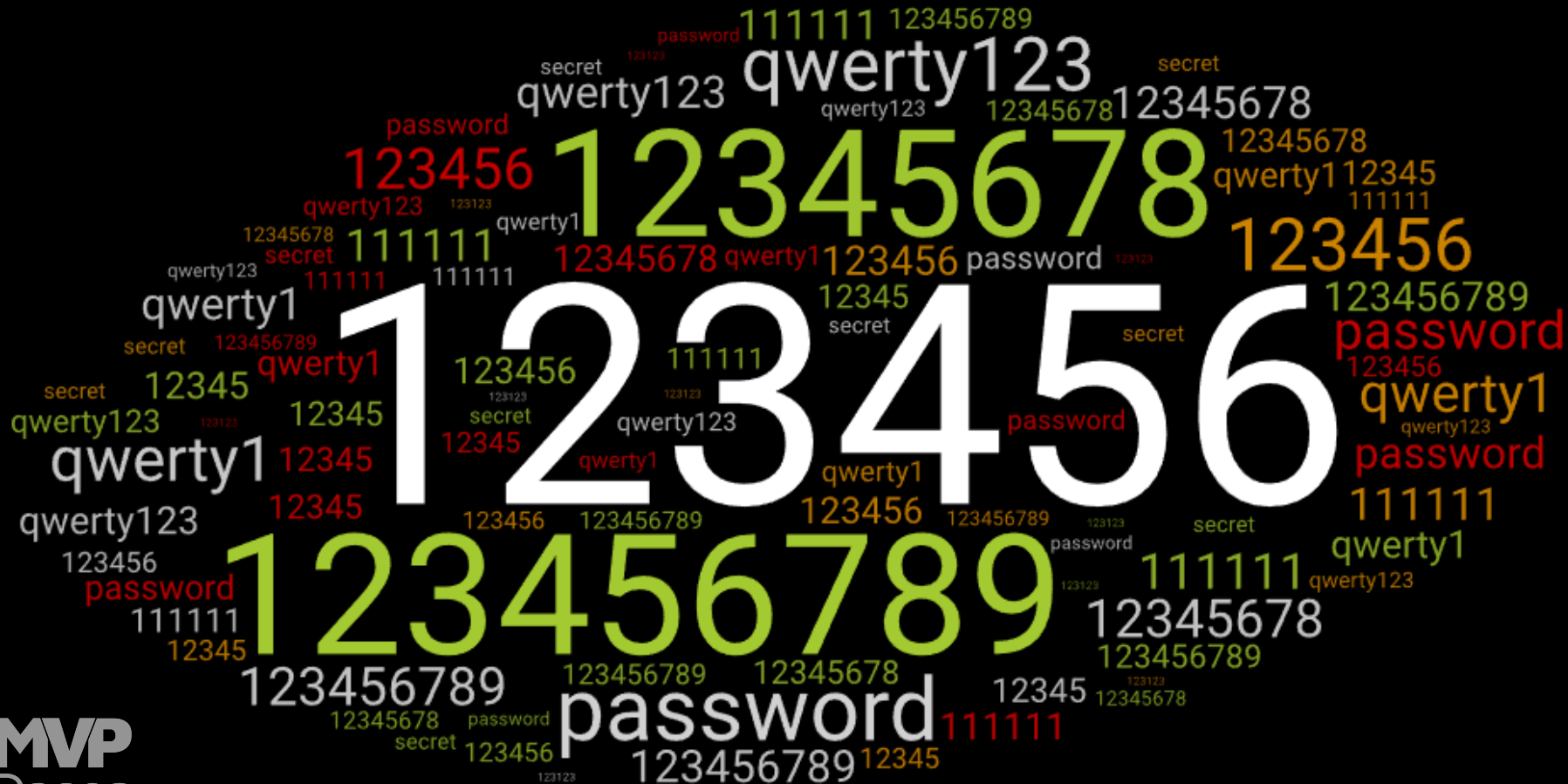
## Jeg heter Jan Ketil

Jeg jobber hos CloudWay

Du finner meg som @JankeSkanke

MVP på 10. året





**Pa\$\$words** are  
expensive and  
insecure

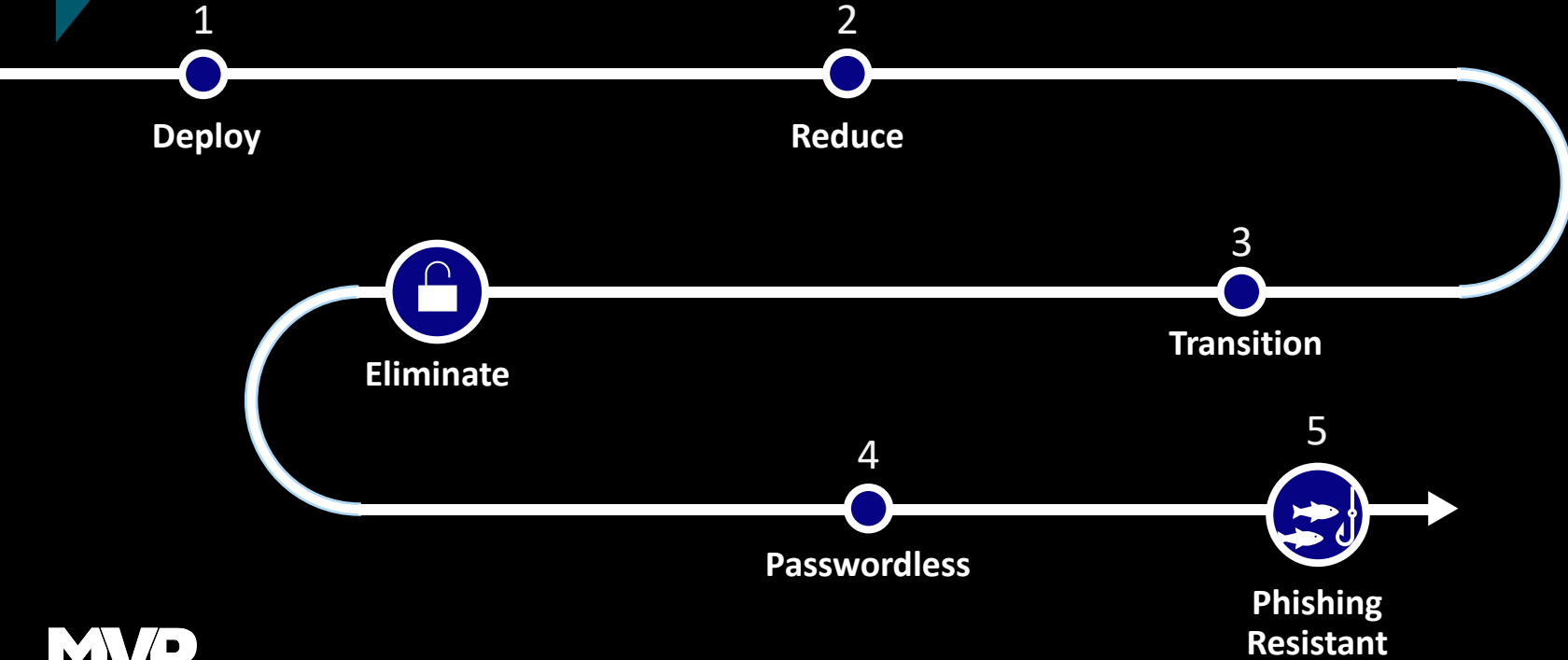
In the time it takes you to read this sentence, Microsoft would have defended against 27,860 individual password attacks.

# Key Updates - NIST 2024 Password Guidance

- ◆ Password length over complexity
  - ◆ Passphrase of 12-16 characters
- ◆ Elimination of Mandatory Password Expiration
  - ◆ Recommends against periodic password changes
  - ◆ Change ONLY when known compromise
- ◆ Support for Diverse Character Sets
  - ◆ . The 2024 update encourages the use of all ASCII characters and even Unicode
- ◆ Prohibition of Password Hints
- ◆ Encouragement of Password Managers
  - ◆ NIST is strongly encouraging the use of password managers



# The Path to Passwordless



# The evolving cyber threat landscape

## Identity Attacks

In the first half of 2025, identity-based attacks rose by 32%.

This escalation may reflect adversaries' increasing use of AI to craft highly convincing social engineering lures—posing new challenges for detection and response at scale.

## Low MFA Adoption

Login attempts using correct username and password, but blocked by multifactor authentication

**1.5%**

## Access Brokers

The hidden gatekeepers of cybercrime.

These actors specialize in breaching enterprise environments and selling persistent access to other criminals, including ransomware operators, data extortion groups, and cyber mercenaries

*Source: Microsoft Digital Defense Report 2025*

# **Key issues** impacting cyber resilience

**Insecure  
configuration  
of identity  
platform**

**Insufficient  
privilege access  
and lateral  
movement  
controls**

**No Multifactor  
authentication  
or lack of  
modern MFA**

**Limited  
adoption of  
modern  
security  
frameworks  
(Zero Trust)**

How can we protect against **99%** of attacks?

The vast majority of successful cyberattacks could be prevented by **implementing a few fundamental** security hygiene practices

# 99%

Basic security hygiene still protects against 99% of attacks.

# 99%

Basic security hygiene still protects against 99% of attacks.



Enable multifactor authentication (MFA)

# 99%

Basic security hygiene still protects against 99% of attacks.



Enable multifactor authentication (MFA)



Apply Zero Trust principles

# 99%

Basic security hygiene still protects against 99% of attacks.



Enable multifactor authentication (MFA)



Apply Zero Trust principles



Use extended detection and response (XDR) and antimalware



# 99%

Basic security hygiene still protects against 99% of attacks.



Enable multifactor authentication (MFA)



Apply Zero Trust principles



Use extended detection and response (XDR) and antimalware

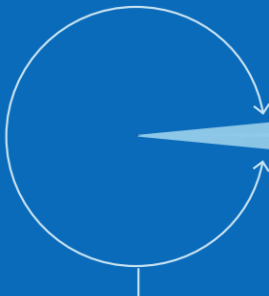


Keep up to date

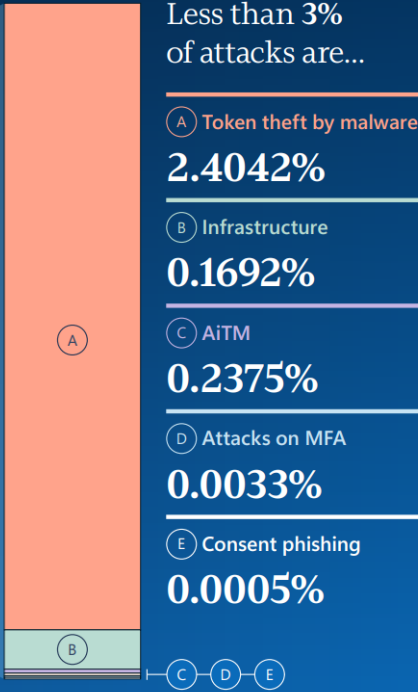
Identity attacks in perspective

Modern multifactor authentication still reduces the risk of identity compromise by more than 99%.

While attacks against identity infrastructure (such as Microsoft Entra, Okta, Identity Provider (IdP), and hybrid components) are still limited in volume and are rare relative to other attacks, their variety is increasing. Novel attacks are continually being discovered, often targeting on-premises to cloud vertical attack paths.



More than **97%** of identity attacks are password spray or brute force attacks



Source: Microsoft Defender XDR and Entra ID Protection alerts (April-June 2025)

Basic security hygiene still protects against  
99% of attacks.



# Conditional Access – Apply Zero Trust Principles

- ◆ All apps are covered
- ◆ All accounts, human or not, have a defined persona
- ◆ Each persona has their own set of policies
- ◆ If no persona is assigned, access is blocked by Global Policy
- ◆ Any exceptions should be group based
  - ◆ Persona = Entra ID Group

# Personas – Conditional Access

## Global

- Placeholder for global policies applying to all users in the tenant

## Admins

- All users with Cloud Admin roles
- Recommended separate account, not synced, for most roles

## Internals

- All employees and internal users (Synced from AD)

## Externals

- All external users with a local accounts (Synced from AD)

## Guest Users

- All guest users in the tenant

## Guest Admins

- Guest users with administrative roles

## Resource Accounts

- Teams Rooms and similar resources that needs to logon

# Personas – Suggested Groups

**CA-Persona-Admins**

Entra ID role-assignable group

**CA-Persona-Internals**

Synced or Entra ID assigned group

**CA-Persona-Externals**

Synced or Entra ID assigned group

**CA-Persona-Guests**

Entra ID Dynamic group

**CA-Persona-BreakGlassAccounts**

Entra ID role-assignable group

**CA-Persona-Global-Exclusions**

Entra ID role-assignable group

# Personas – Naming Convention

|           | Naming component | Description/Example                                                                                                                    |
|-----------|------------------|----------------------------------------------------------------------------------------------------------------------------------------|
| CA Number | CA Number        | Used to quickly identify Policy Type scope and order. Example: CA001-CA099.                                                            |
| Persona   | Persona          | Global, Admins, Internals, Externals, GuestUsers, GuestAdmins, Microsoft365ServiceAccounts, AzureServiceAccounts, CorpServiceAccounts. |
| App       | App              | AllApps, O365 (for all Office 365 services), EXO (for Exchange Online).                                                                |
| Platform  | Platform         | AnyPlatform, Unknown, WindowsPhone, macOS, iOS, Android.                                                                               |
| Grant     | Grant Control    | Block, ADHJ, Compliant, Unmanaged (where unmanaged is specified in the device state condition).                                        |
| MVP Dagen | Description      | Optional description of the purpose of the policy.                                                                                     |

CA Number

Persona

App

Platform

Grant



## Conditional Access | Policies

Microsoft Entra ID



Overview



Policies



Insights and reporting



Diagnose and solve problems

## Manage



Named locations



Custom controls (Preview)



Terms of use



VPN connectivity



Authentication contexts



Authentication strengths



New policy



New policy from template



Upload policy file



What If



Refresh

CA001-Global-BaseProtection-AllApps-AnyPlatform-NonPersonas-Block

CA002-Global-AllApps-AnyPlatforms-LegacyAuth-Block

CA100-Admins-BaseProtection-AllApps-AnyPlatforms-MFA-Grant

CA101-Admins-AllApps-MediumAndHighUserRisk-MFAandChangePwd-Grant

CA102-Admins-AllApps-AnyPlatform-MediumandHighSignInRisk-MFA-Grant

CA103-Admins-AllApps-AnyPlatform-SignInFrequency-4hours-Session

CA200-Internals-AllApps-AnyPlatform-CompliantorHAADJorMFA-Grant

CA201-Internals-AllApps-HighUserRisk-MFAandChangePwd-Grant

CA202-Internals-AllApps-AnyPlatform-HighSignInRisk-MFA-Grant

CA205-Internals-AllApps-UnknownPlatforms-Block

CA206-Internals-DeviceRegistrationAndAADJoin-MFA-Grant

CA300-Externals-AllApps-AnyPlatform-CompliantorHAADJorMFA-Grant





# Privileged Identity Management

- ◆ Always think least privilege
- ◆ Always use dedicated accounts
- ◆ Don't sync your admin accounts if hybrid
- ◆ Find a good governance model for your privileged access
  - ◆ Make sure people don't stay in roles if not needed.
- ◆ Use Entra ID Privileged Identity Management (PIM)
  - ◆ Request approvals or not?

PIM Setup



| <input type="checkbox"/> | Name ↕                                                            | Group type | Membership type | Source | Role assignments allowed |
|--------------------------|-------------------------------------------------------------------|------------|-----------------|--------|--------------------------|
| <input type="checkbox"/> | <div>AR</div> AZ-Role-Privileged Role Administrator               | Security   | Assigned        | Cloud  | Yes                      |
| <input type="checkbox"/> | <div>AI</div> AZ-Role-Azure Information Protection Administrat... | Security   | Assigned        | Cloud  | Yes                      |
| <input type="checkbox"/> | <div>AD</div> AZ-Role-Azure DevOps Administrator                  | Security   | Assigned        | Cloud  | Yes                      |
| <input type="checkbox"/> | <div>AD</div> AZ-Role-Teams Devices Administrator                 | Security   | Assigned        | Cloud  | Yes                      |
| <input type="checkbox"/> | <div>AA</div> AZ-Role-Conditional Access Administrator            | Security   | Assigned        | Cloud  | Yes                      |
| <input type="checkbox"/> | <div>AA</div> AZ-Role-Security Administrator                      | Security   | Assigned        | Cloud  | Yes                      |
| <input type="checkbox"/> | <div>AO</div> AZ-Role-Security Operator                           | Security   | Assigned        | Cloud  | Yes                      |
| <input type="checkbox"/> | <div>AA</div> AZ-Role-Search Administrator                        | Security   | Assigned        | Cloud  | Yes                      |



# AZ-Role-Security Administrator | Properties ...

Group



Properties



Members



Owners



Roles and administrators



Administrative units



Group memberships



Assigned roles



Applications



Licenses



Azure role assignments

## Activity



Privileged Identity Management



Access reviews



Audit logs



Save



Discard



Got feedback?

## General settings

Group name \* ⓘ

AZ-Role-Security Administrator



Group description ⓘ

This group is assigned to Security Administrator built-in role in Entra ID



Group type

Security



Membership type ⓘ

Assigned



Object Id

[REDACTED]



Microsoft Entra roles can be assigned to the group ⓘ

Yes

No

Group writeback state

No writeback



Eligible assignments

Active assignments

Expired assignments

 Search by member name or principal name

| Name                                                  | Principal name | Type  | Scope     | Membership | Start time             | End time  | Action                                          |
|-------------------------------------------------------|----------------|-------|-----------|------------|------------------------|-----------|-------------------------------------------------|
| Insights Administrator                                |                |       |           |            |                        |           |                                                 |
| <a href="#">AZ-Role-Insights Administrator</a>        | -              | Group | Directory | Direct     | 2/16/2022, 1:55:39 PM  | Permanent | <a href="#">Remove</a>   <a href="#">Update</a> |
| Insights Analyst                                      |                |       |           |            |                        |           |                                                 |
| <a href="#">AZ-Role-Insights Administrator</a>        | -              | Group | Directory | Direct     | 5/31/2023, 12:49:43 AM | Permanent | <a href="#">Remove</a>   <a href="#">Update</a> |
| Intune Administrator                                  |                |       |           |            |                        |           |                                                 |
| <a href="#">AZ-Role-Intune Administrator</a>          | -              | Group | Directory | Direct     | 2/16/2022, 1:55:11 PM  | Permanent | <a href="#">Remove</a>   <a href="#">Update</a> |
| Knowledge Administrator                               |                |       |           |            |                        |           |                                                 |
| <a href="#">AZ-Role-Knowledge Administrator</a>       | -              | Group | Directory | Direct     | 2/16/2022, 1:56:04 PM  | Permanent | <a href="#">Remove</a>   <a href="#">Update</a> |
| Knowledge Manager                                     |                |       |           |            |                        |           |                                                 |
| <a href="#">AZ-Role-Knowledge Manager</a>             | -              | Group | Directory | Direct     | 2/16/2022, 2:57:26 PM  | Permanent | <a href="#">Remove</a>   <a href="#">Update</a> |
| License Administrator                                 |                |       |           |            |                        |           |                                                 |
| <a href="#">AZ-Role-License Administrator</a>         | -              | Group | Directory | Direct     | 2/16/2022, 1:55:28 PM  | Permanent | <a href="#">Remove</a>   <a href="#">Update</a> |
| Message Center Privacy Reader                         |                |       |           |            |                        |           |                                                 |
| <a href="#">AZ-Role-Message Center Privacy Reader</a> | -              | Group | Directory | Direct     | 2/16/2022, 1:55:42 PM  | Permanent | <a href="#">Remove</a>   <a href="#">Update</a> |

# Access review details | Overview

«

Overview

## Current

- Results
- Reviewers
- Settings
- Audit logs

## Series

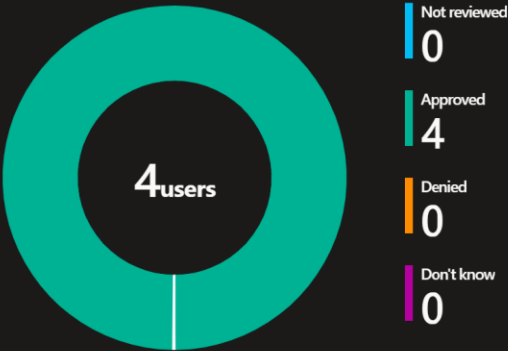
- Reviewers
- Settings
- Scheduled review
- Review history
- Audit logs

Delete series

### ^ Essentials

|                      |   |                                |                    |   |                |
|----------------------|---|--------------------------------|--------------------|---|----------------|
| Owner                | : |                                | Scope              | : | Everyone       |
| Group                | : | AZ-Role-Security Administrator | Review status      | : | Active         |
| Access review period | : | 9/11/2023 - No end date        | Selected reviewers | : | Selected users |
| Object Id            | : |                                | Description        | : |                |
|                      |   |                                | Recurrence type    | : | Quarterly      |

### Previous



Access review details | Review history ...

- «

Overview

Current

Results

Reviewers

Settings

Audit logs

Series

Reviewers

Settings

Scheduled review

Review history

Search

| Review Name                        | ↑↓ | Start Date | ↑↓ | End Date  | ↑↓ | Status         |
|------------------------------------|----|------------|----|-----------|----|----------------|
| Global Admin Access Monthly Review |    | 5/26/2024  |    | 6/1/2024  |    | Result applied |
| Global Admin Access Monthly Review |    | 4/26/2024  |    | 5/2/2024  |    | Result applied |
| Global Admin Access Monthly Review |    | 3/26/2024  |    | 4/1/2024  |    | Result applied |
| Global Admin Access Monthly Review |    | 2/26/2024  |    | 3/3/2024  |    | Result applied |
| Global Admin Access Monthly Review |    | 1/26/2024  |    | 2/1/2024  |    | Result applied |
| Global Admin Access Monthly Review |    | 12/26/2023 |    | 1/1/2024  |    | Result applied |
| Global Admin Access Monthly Review |    | 11/26/2023 |    | 12/2/2023 |    | Result applied |
| Global Admin Access Monthly Review |    | 10/26/2023 |    | 11/1/2023 |    | Result applied |
| Global Admin Access Monthly Review |    | 9/26/2023  |    | 10/2/2023 |    | Result applied |
| Global Admin Access Monthly Review |    | 8/26/2023  |    | 9/1/2023  |    | Result applied |



# s | Review history ...

<<

 Search

| Review Name                        | ↑↓ | Start Date | ↑↓ | End Date  | ↑↓ |
|------------------------------------|----|------------|----|-----------|----|
| Global Admin Access Monthly Review |    | 5/26/2024  |    | 6/1/2024  |    |
| Global Admin Access Monthly Review |    | 4/26/2024  |    | 5/2/2024  |    |
| Global Admin Access Monthly Review |    | 3/26/2024  |    | 4/1/2024  |    |
| Global Admin Access Monthly Review |    | 2/26/2024  |    | 3/3/2024  |    |
| Global Admin Access Monthly Review |    | 1/26/2024  |    | 2/1/2024  |    |
| Global Admin Access Monthly Review |    | 12/26/2023 |    | 1/1/2024  |    |
| Global Admin Access Monthly Review |    | 11/26/2023 |    | 12/2/2023 |    |
| Global Admin Access Monthly Review |    | 10/26/2023 |    | 11/1/2023 |    |
| Global Admin Access Monthly Review |    | 9/26/2023  |    | 10/2/2023 |    |
| Global Admin Access Monthly Review |    | 8/26/2023  |    | 9/1/2023  |    |

# Be aware – clicking this one might cost you some money !!!

× ‹ + Add assignments ⚙ Settings ↻ Refresh ↓ Export | 🗨 Got feedback?

- Overview
- Diagnose and solve problems
- Manage
  - Properties
  - Members
  - Owners
  - Roles and administrators
  - Administrative units
  - Group memberships
  - Applications
  - Licenses
  - Azure role assignments
- Activity
  - Privileged Identity Management** ☆
  - Access reviews
  - Audit logs
  - Bulk operation results
- Troubleshooting + Support
  - New support request



## PIM for groups

Microsoft Entra Privileged Identity Management (PIM) enables just-in-time (JIT) access to the ownership or membership of the group.

[Enable PIM for this group](#)



### Learn more about PIM

Enforce just-in-time access for owners and members of this group by requiring them to activate for a limited period of time. Create just-in-time access policies for these users like approval workflow, MFA challenge and much more.



### Activate more in less time

Assign multiple roles to a single group so that users only need to activate once to get all the permissions they need.

# Emergency Accounts

- ✓ Failsafe account for emergencies
- ✓ Excluded from All CA Policies
- ✓ Monitored
- ✓ FIDO 2 Keys for Strong Auth
- ✓ Complex Password stored safely

**Recommendation:** Create at least two of these accounts, and never store physical ID's in the same location



# Be Aware

- ◆ Authentication Policy Administrator can remove AA GUIDS or delete Auth Methods
  - ◆ This will block / disable all keys with the AAGUIDS
  - ◆ They can't logon

☐ Authentication Administrator

Can access to view, set and reset authentication method information for any non-admin user.

PRIVILEGED

☐ Authentication Extensibility Administr...

Customize sign in and sign up experiences for users by creating and managing custom authentication extensions.

PRIVILEGED

☐ Authentication Policy Administrator

Can create and manage the authentication methods policy, tenant-wide MFA settings, password protection policy, and verifiable credentials.

Can access to view, set and reset



## Choose a way to sign in

Your sign-in was successful but this passkey does not meet the criteria set by your admin. Try signing in with a different passkey. Alternatively, contact your admin for help.



Face, fingerprint, PIN or security key

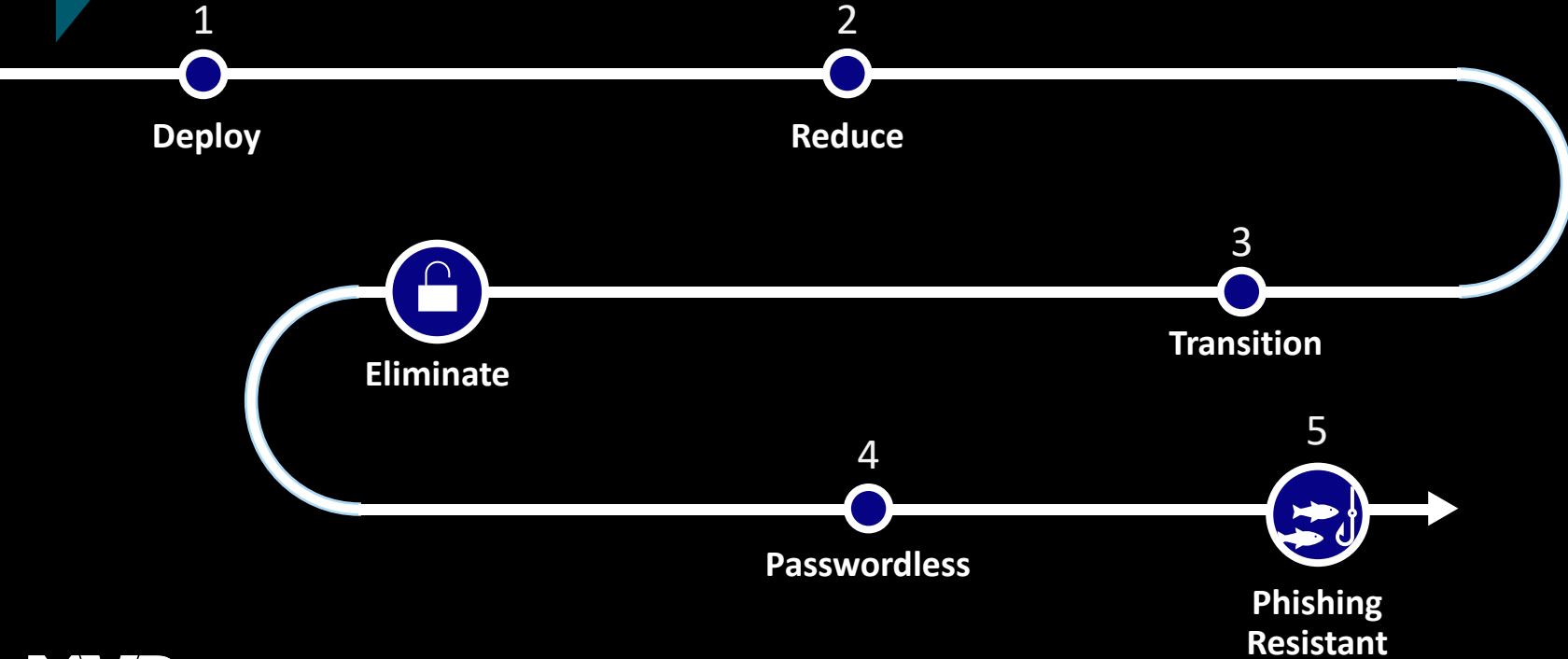


Approve a request on my Microsoft Authenticator app



Use my password

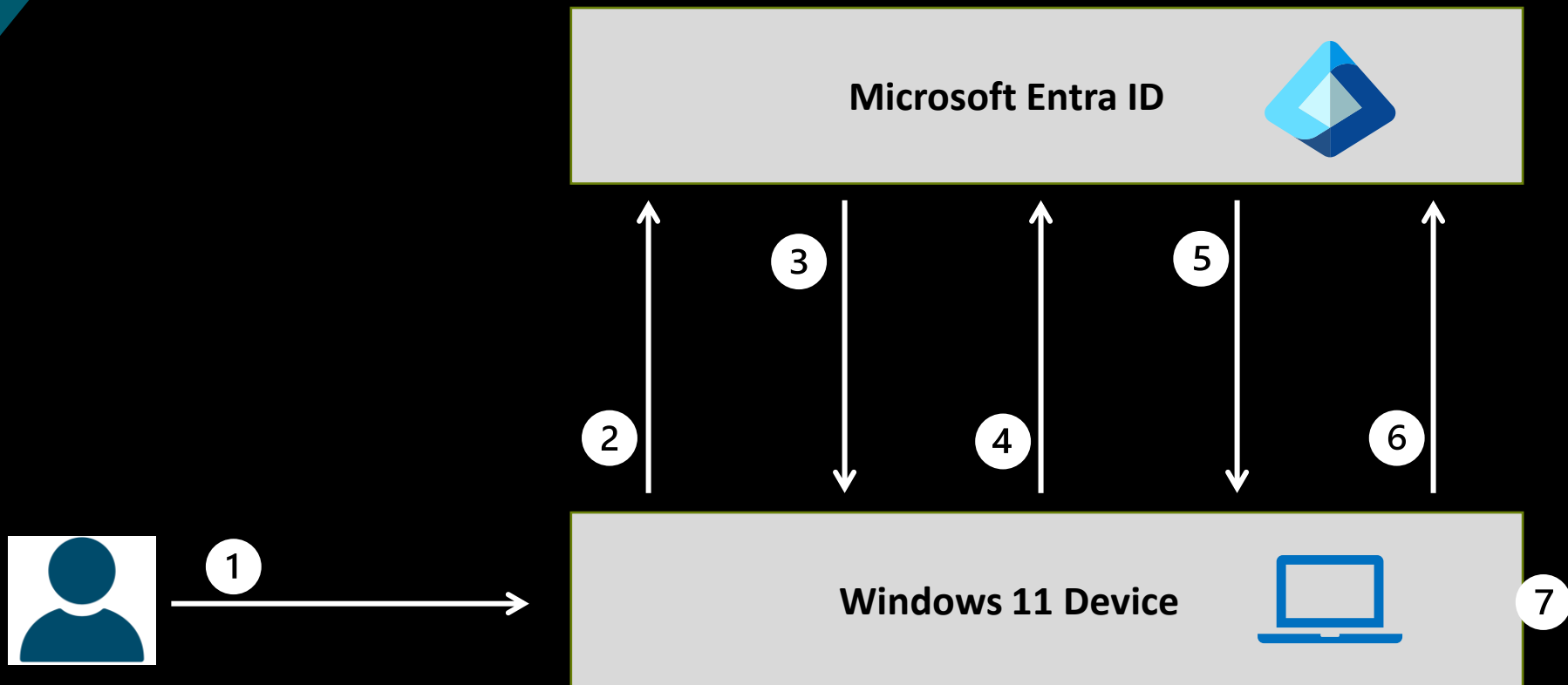
# The Path to Passwordless



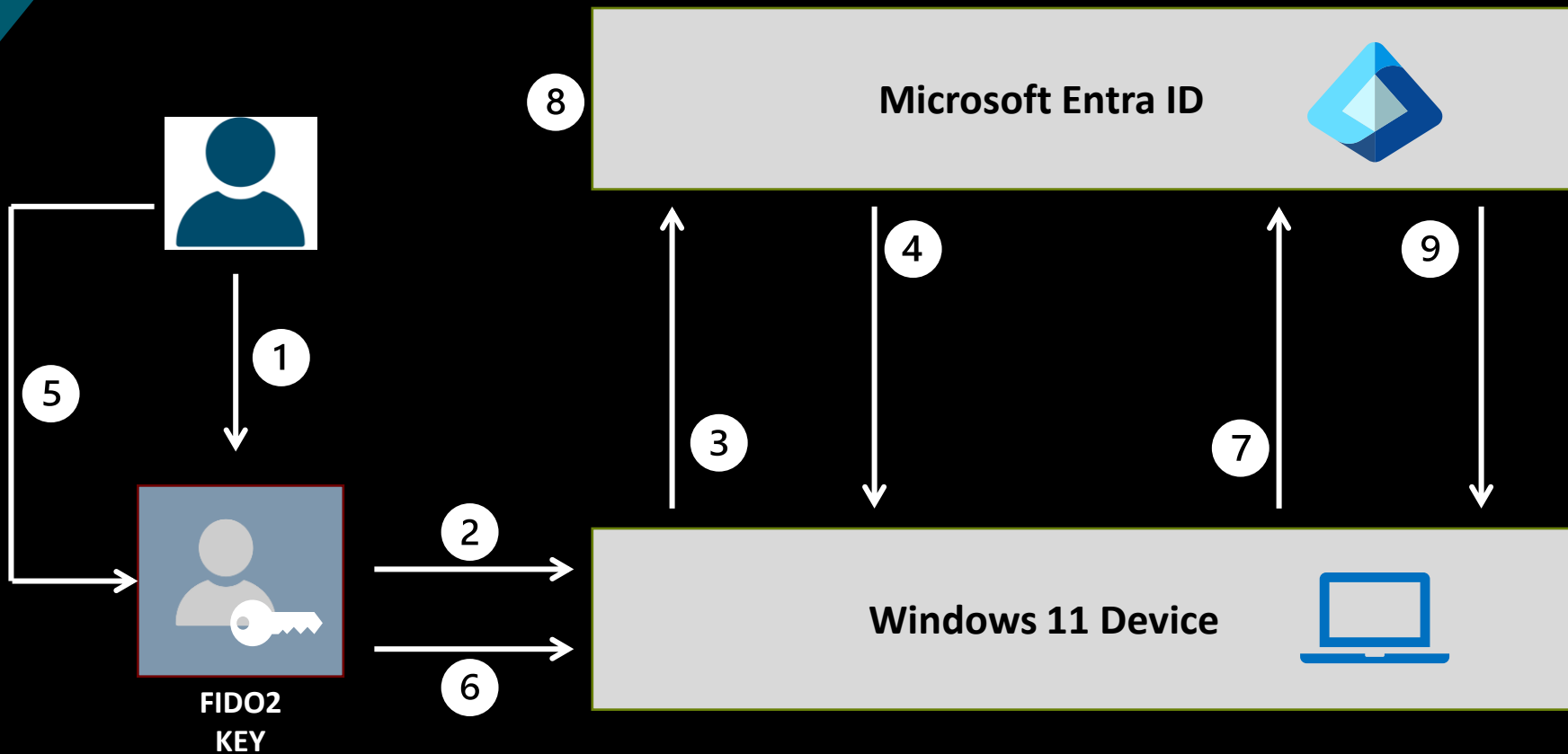
# What is Phishing Resistant

- ♦ Any authenticator that involves the manual entry of an authenticator output, such as an OTP, password, or other knowledge factor, is not considered phishing-resistant.
- ♦ The leading forms of phishing-resistant authentication include PKI and FIDO authenticators.
- ♦ Device Bound Passkeys  $\approx$  FIDO
  - ♦ Uses same cryptographic approach

# Windows Hello for Business

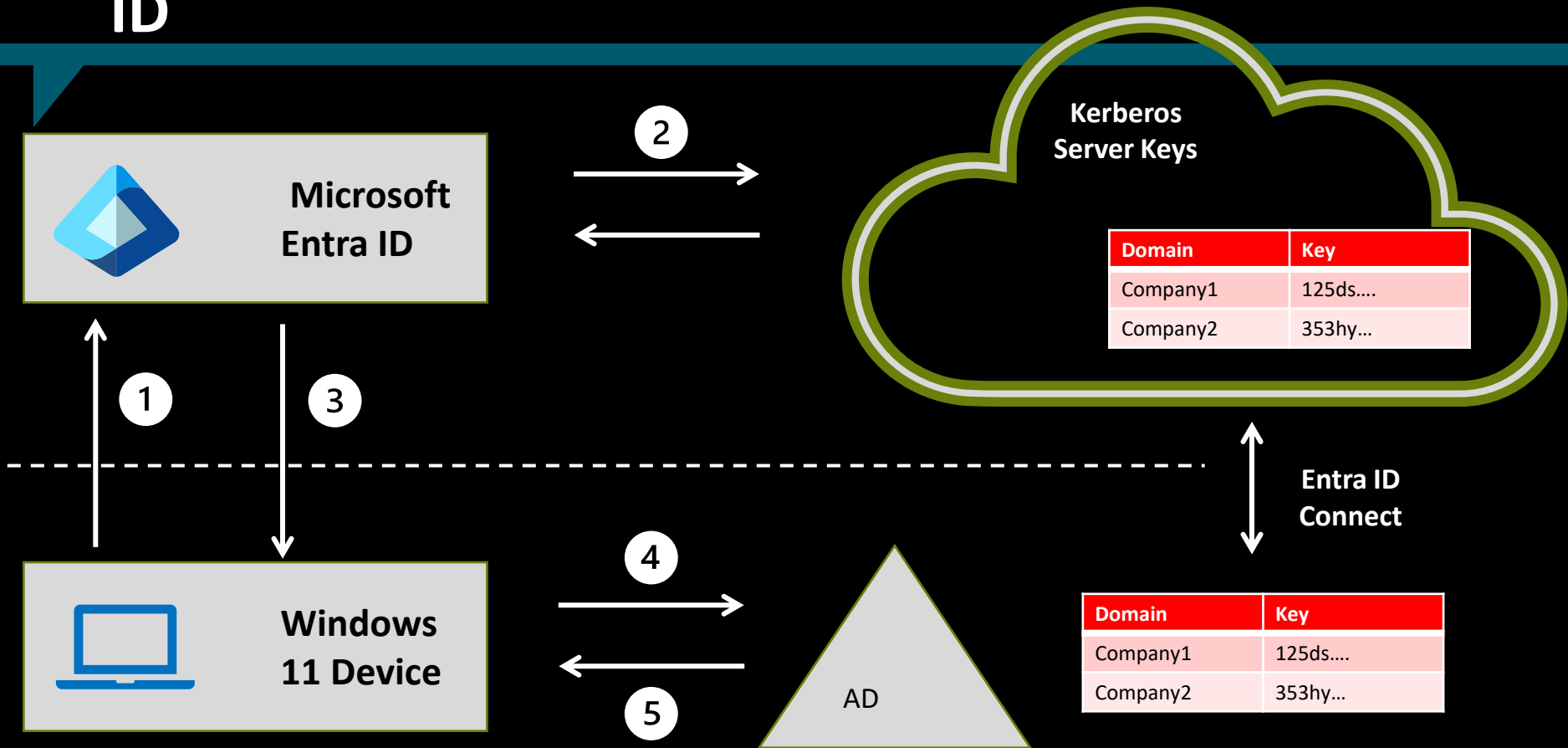


# FIDO 2 Security Key





# Phishing Resistant Auth On-premises with Entra ID

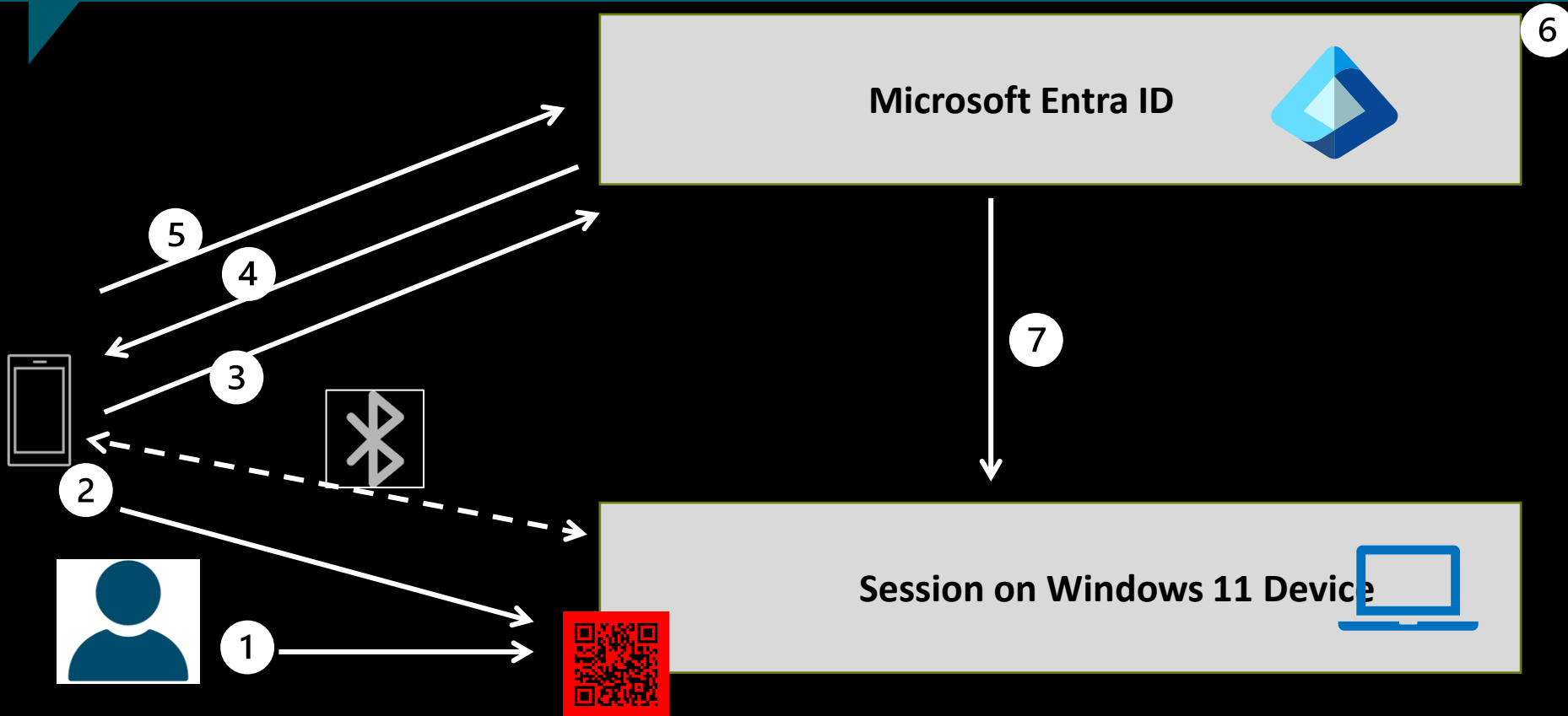


# Device Bound Passkey in Authenticator

- ◆ Android 14 and later or iOS 17 and later.
- ◆ An active internet connection on any device that's part of the passkey registration/authentication process. Connectivity to these two endpoints must be allowed in your organization to enable cross-device registration and authentication:
  - ◆ <https://cable.ua5v.com>
  - ◆ <https://cable.auth.com>
- ◆ For cross-device registration/authentication, both devices must have Bluetooth enabled.

| Scenario                                                    | iOS | Android        |
|-------------------------------------------------------------|-----|----------------|
| Same-device authentication in a browser                     | ✓   | ✓ <sup>1</sup> |
| Same-device authentication in native Microsoft applications | ✓   | ✓              |
| Cross-device authentication                                 | ✓   | ✓              |

# Device Bound Passkey in Authenticator



# References

- ◆ [Microsoft Digital Defense Report 2025](#)
- ◆ [Microsoft Entra passwordless sign-in - Microsoft Entra ID | Microsoft Learn](#)
- ◆ [Microsoft Authenticator authentication method - Microsoft Entra ID | Microsoft Learn](#)
- ◆ [Enable passkeys in Authenticator for Microsoft Entra ID - Microsoft Entra ID | Microsoft Learn](#)
- ◆ [Support for passkeys in Windows | Microsoft Learn](#)
- ◆ [WebAuthn Passkey QR Codes & Bluetooth: Hybrid Transport](#)
- ◆ [FAQs for hybrid FIDO2 security key deployment - Microsoft Entra ID | Microsoft Learn](#)
- ◆ [Enable passkeys for your organization - Microsoft Entra ID | Microsoft Learn](#)
- ◆ [Considerations for specific personas in a phishing-resistant passwordless authentication deployment in Microsoft Entra ID - Microsoft Entra ID | Microsoft Learn](#)
- ◆ [Windows Hello for Business cloud Kerberos trust deployment guide | Microsoft Learn](#)
- ◆ [Windows Hello for Business on-premises key trust deployment guide | Microsoft Learn](#)

# Takk!

## Spørsmål?

Du finner meg på

- ▶ @JankeSkanke

